OSCP Journey !!! I never lose, I either win or learn !!!



Jie Liau Follow
Oct 30, 2019 · 8 min read



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

If you never try it, you won't earn it. Recently I just completed PWK courses and earned my OSCP certification. It's really a hard journey and it deserves to be my very first story on Medium!

After this, I will keep posting related technical stories which was found and re-organized during my preparation of OSCP. Please stay tuned.

\x01 Before OSCP

I heard OSCP about one year ago and think this would be significant milestone to my career path. Before starting your PWK course, I strongly recommend to try yourself on VulnHub and Hack In The Box. I sometimes spent all my weekend on VulnHub and Hack In The Box. I list some OSCP-like machines below and you could give it a try before you jump into the PWK course.

Vulnhub		Hack In The Box	
Kioptrix: Level 1 (#1)	Pinkys Palace v1	**Linux**	**Windows**
Kioptrix: Level 1.1 (#2)	Pinkys Palace v2	Lame	legacy
Kioptrix: Level 1.2 (#3)	Zico2	brainfuck	Blue
Kioptrix: Level 1.3 (#4)	Wintermute	shocker	Devel
Kioptrix: 2014	Lord of the root 1.0.1	bashed	Optimum

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

FristiLeaks 1.3	Tr0ll 1	nibbles	Bastard
Stapler 1	Tr0ll 2	beep	granny
VulnOS 2	Web Developer 1	cronos	Arctic
SickOs 1.2	SolidState	nineveh	grandpa
Brainpan 1	Hackme 1	sense	silo
HackLAB: Vulnix	Escalate_Linux: 1	solidstate	bounty
/dev/random: scream	DC: 6	node	jerry
pWnOS 2.0		valentine	conceal
SkyTower 1		poison	chatterbox
Mr-Robot 1		sunday	
PwnLab		tartarsauce	
Metasploitable 3		Irked	
Lin.Security		Friendzone	
Temple of Doom		Swagshop	

\x02 Starting OSCP journey

Offensive Security's PWK course has 3 course packages - 30 days, 60 days and 90 days. If penetration testing is your daily job, I believe 30 or 60 days will be enough to you. Once completing your registration of PWK, you have to wait few days and then will receive the mail to indicate where to download your course manual, video and PWK version of Kali Linux Vmware image. In the same mail, you will be provided your OS id, login password and VPN connectivity information as well. At this point, you

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

might be able to start your self-learning journey and enjoy your exhausted Lab time. I signed up for 90 days course package and spent about 2 weeks to complete course material and jump into to the Lab soon after this. The less time you spend on course material, the more lab time you will get. All in 90 days. If you think 90 days is not enough, you could pay to get more.

\x03 Lab time



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

There are 4 subnets in the lab environment - public, development, IT and administrative. You goal is to fully compromise the machine to get **proof.txt**. In some machines, you will see **network-secret.txt** as well, this is the key for you to connect to other subnets, like development, IT and administrative subnets.

Once you connect into VPN, public subnet is the first one you will be in. There are around 40 boxes in it. There is no rule for your starting point. You could start from the first machine or last one. It's all up to you but some machines will have so called — relationship. That means you have to compromise that machine first to break into this machine. Lots of attack vector you could utilize, like SQLi, shellshock, LFI, RFI, BufferOverflow and so on. Offensive Security Lab environment is trying to simulate one environment like the real world. You will face Windows, Linux and BSD platform. Don't be so scared and stay calm !!!

During my 90 days lab time, I compromised 37 machines totally and have IT, development subnet access. I rooted/pwned timeclock, sean, kevin,

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

core, joe, phoenix, barry, tophat, alpha, RALPH, DJ, ORACLE, jd, kraken, susie, BOB, sherlock, mike, sufferance, pain, fc4, BOB2, leftturn, hotline, mail, alice, HELPDESK, gh0st, gamma, dotty, beta, pedro, jeff, BRUCE, payday, master and observer. If you are chasing you OSCP, you could probably hear about 5 most notorious and infamous machines — **gh0st**, **fc4**, **pain**, **humble** and **sufferance**. Near the end of my 90 days lab time, I was stuck on humble. It obviously could be RCE via NoSQL vulnerability and I did sleep MongoDB for a while but I was unable to reverse shell back to my Kali. Tried a lot but still no luck. Finally lab time ended. Honestly, Offensive Security Lab is the best security lab I've ever seen. Even you already pass OSCP, it's also recommended to swipe your credit card for more time to get all hosts compromised.

\x04 Game On

Once your lab ends, you have to schedule your exam date in 90 days and you have up to 3 times to re-schedule it. Be attention that your OSCP exam will be proctored by your webcam and screen sharing, so if you want to take you OSCP exam on the weekend. Schedule your exam 4 weeks earlier before the date you want. You can even schedule it during your lab time is still going on.

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Before your exam starts, the Offensive Security staff will do identity check. You might be asked to show your passport and surround your room using your webcam. Once your identity is confirmed, your exam lab environment will be unlocked.

In OSCP exam, you have to compromise 5 machines in 24 hours (23 hours 45 mins exactly) and you need to prepare your professional penetration testing report in coming 24 hours. The passing score is 70 points. The points for each machine is 25, 25, 20, 20 and 10 respectively. Your goal is to get local.txt and proof.txt. And please remember to screenshot your local.txt/proof.txt along with ipconfig/ifconfig. If you don't do it, you may loss full point on that machine. In my OSCP exam, I successfully rooted 4/5 machines and the most impressive part during my OSCP exam was I got one Windows10 machine and successfully escalated myself to SYSTEM. This machine spent lots of my time during the exam. But finally I succeeded. Never give up. TRIED HARDER !!!

\x05 Miscellaneous

Don't miss the exploit development part in the course material. Please read buffer overflow exploit development for Windows and Linux super carefully

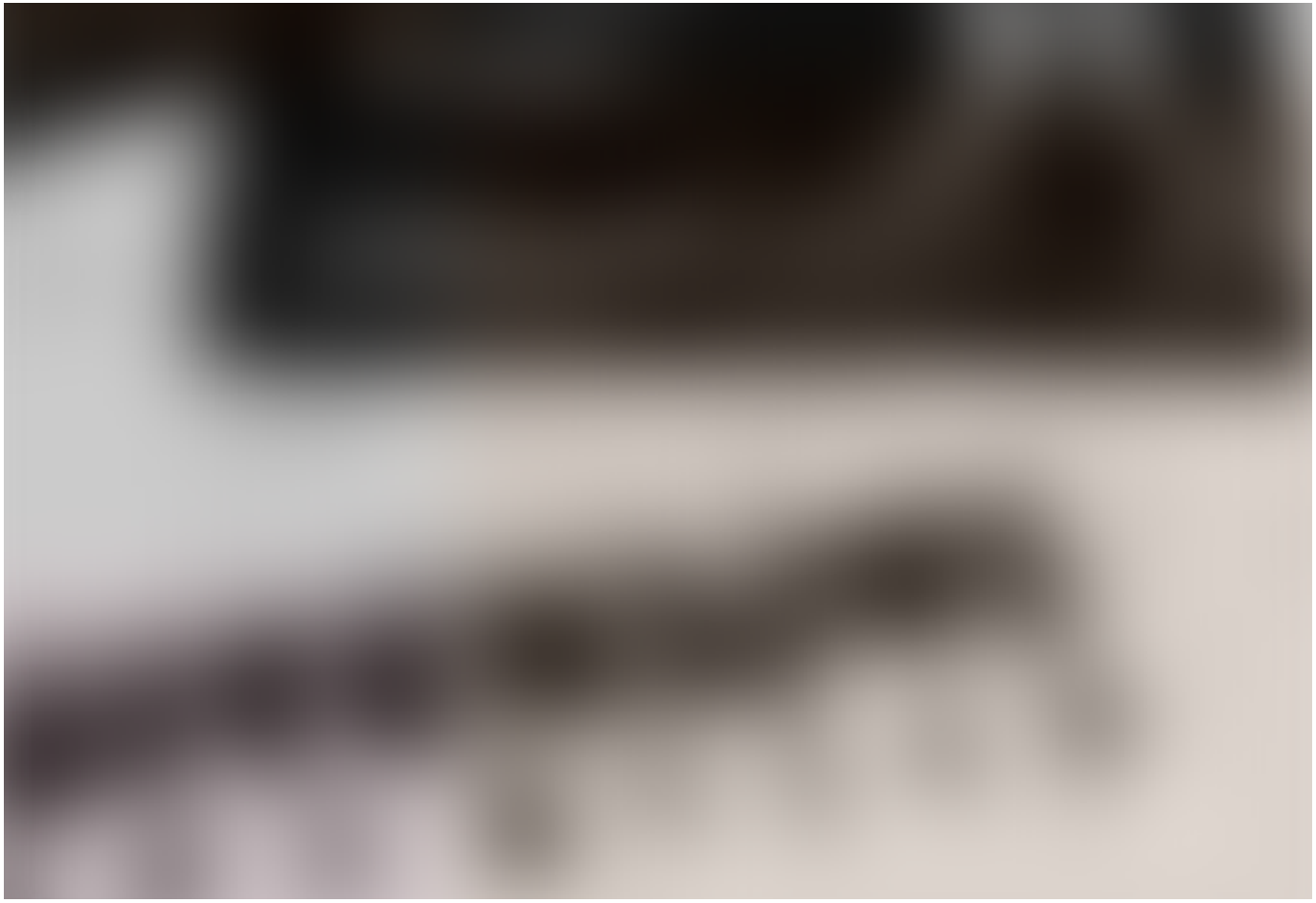
Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

!!! This will be the compulsory machine in the OSCP exam and it is 25 points !!! Fully understanding how to control EIP and how to generate shellcode will be much fun and be helpful in your security career path so much.

Finally, I tried harder and passed it !!!



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD



In the end of this article, I list some useful website below. Those are the ones I frequently visit during the preparation of my OSCP. Hope you guys have a wonderful learning and enjoy it !!!

Windows Privilege Escalation and pen-testing

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

FuzzySecurity | Windows Privilege Escalation Fundamentals

Not many people talk about serious Windows privilege escalation which is a shame. I think the reasons for this are...

www.fuzzysecurity.com



ankh2054/windows-pentest

Windows Pentest Scripts and Tools. Uses WMIC to gather various important informatoon about a windows host and dump it...

github.com



Windows Privilege Escalation Guide

Privilege escalation always comes down to proper enumeration. But to accomplish proper enumeration you need to know...

www.absolomb.com

Github resources

offensive-security/exploitdb-bin-sploits



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Exploit Database binary exploits located in the /sploits directory - offensive-security/exploitdb-bin-sploits

github.com



backlion/oscp-7

Scripts and things that I have created when I was doing OSCP. I tried to prevent spoilers and other informations...

github.com

gammathc/oscp_material

This file conains all the notes i did during my preparation for the OSCP exam.

github.com



3mrgnc3/LFIter2

You can't perform that action at this time. You signed in with another tab or window. You signed out in another tab or...

github.com

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Pentesting Notes

Notes essentially from OSCP days Discover service versions of open ports using nmap or manually. nmap: Use -p- for all...

malikashish8.github.io

Introduction

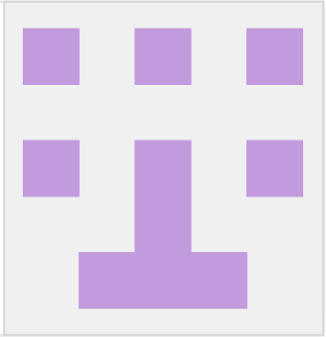
My notepad about stuff related to IT-security, and specifically penetration testing. Stuff I have come across that I...

sushant747.gitbooks.io

ibr2/pwk-cheatsheet

I want to share a couple of things that I think helped me preparing the Offensive Security Certified Professional ...

github.com



LFI to RCE

Local File Inclusion (LFI) — Web Application Penetration Testing

The definitive guide for LFI vulnerability security testing for bug hunting & penetration testing engagements.



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD



medium.com

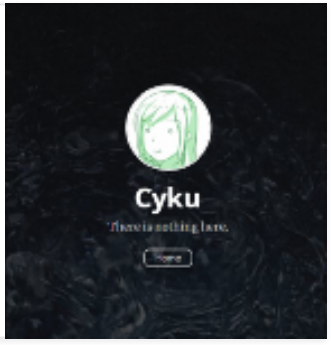
http://www.am0s.com/wp-content/uploads/2017/01/lfi%E4%B8%AD%E6%B3%84%E6%BC%8F%E4%BF%A1%E6%81%AF%E7%9A%84%E6%96%87%E4%BB%B6fuzz.txt



From Local File Inclusion to Code Execution

Local File Inclusion (LFI) is one of the most popular attacks in Information Technology. In this article, we are not...

resources.infosecinstitute.com



[Web Security] 透過 LFI 引入 PHP session 檔案觸發 RCE

先前因為朋友分享而得知某個小站具有 LFI 漏洞，於是就想嘗試著觸發 RCE，但發現主機上檔案權限蠻嚴格的，幸好最終還是成功透過...

cyku.tw

3mrgnc3/LFIter2

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

You can't perform that action at this time. You signed in with another tab or window. You signed out in another tab or...

github.com

RCE with LFI and SSH Log Poisoning

In this article, you will learn how to make unauthorized access in a web server if it is suffering from local file...

www.hackingarticles.in



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Reverse Shell Cheat Sheet

phillips321.co.uk

There are many pages on the web documenting quick reverse shell one liners. Pentestmonkey and Bernardo Damele have both...

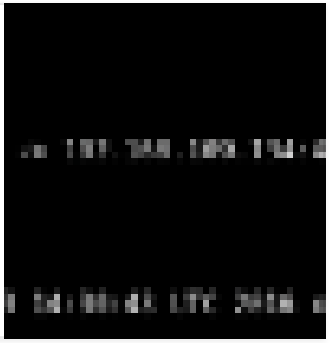
www.phillips321.co.uk

Tomcat port 8009 AJP13 Exploit

Exploiting Apache Tomcat through port 8009 using the Apache JServ Protocol | Ionize

By default, Apache Tomcat listens on 3 ports, 8005, 8009 and 8080. A common misconfiguration is blocking port 8080 but...

ionize.com.au



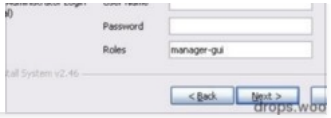
Tomcat的8009端口AJP的利用

Tomcat在安装的时候会有下面的界面，我们通常部署war，用的最多的是默认的8080端口。 可是当8080端口被防火墙封闭的时候，是否...



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

drops.xmd5.com



Linux Kernel Privilege Escalation

Kabot/Unix-Privilege-Escalation-Exploits-Pack

You can't perform that action at this time. You signed in with another tab or window. You signed out in another tab or...

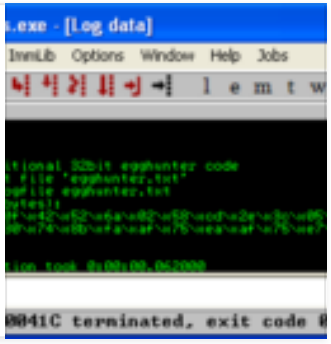
github.com

Buffer Overflow Stuff

Windows Exploitation: Egg hunting

Lately, I've been exploring the world of Windows exploitation. I was already familiar with the concept of Buffer...

medium.com



Privilege Escalation Collection

OSCP Notes - Privilege Escalation (Linux)

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Lynis https://cisofy.com/lynis/ Linux Exploit Suggestor https://github.com/PenturaLabs/Linux_Exploit_Suggester Shell...

securism.wordpress.com

Udev privilege Escalation

Udev Exploit Allows Local Privilege Escalation

A nasty new udev vulnerability is floating around in the wild that allows local users on Linux systems with udev and...

www.madirish.net

Port Knocking

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Reading Room

Featuring 42 Papers as of December 5, 2017 Most of the computer security white papers in the Reading Room have been...

www.sans.org



Windows Kernel Exploits

https://411hall.github.io/assets/images/exploitexcel.png

SecWiki/windows-kernel-exploits

windows-kernel-exploits Windows平台提权漏洞集合. Contribute to SecWiki/windows-kernel-exploits development by creating an...

github.com



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

EternalBlue exploit — MS17–010

How to Exploit EternalBlue on Windows Server with Metasploit

Particular vulnerabilities and exploits come along and make headlines with their catchy names and impressive potential...

null-byte.wonderhowto.com



How to Manually Exploit EternalBlue on Windows Server Using MS17-010 Python Exploit

EternalBlue was a devastating exploit that targeted Microsoft's implementation of the SMB protocol. Metasploit contains...

null-byte.wonderhowto.com



3ndG4me/AutoBlue-MS17-010

This is some no-bs public exploit code that generates valid shellcode for the eternal blue exploit and scripts out the...

github.com

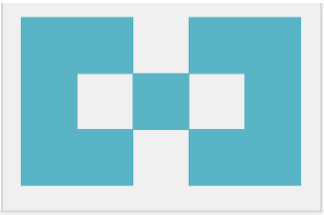
worawit/MS17-010



Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

This repository is for public my work on MS17-010. I have no plan to do any

github.com



Exploiting MS17-010 EternalBlue Vulnerability

Here is a quick tip for you: If you are a Pentester that rely on Metasploit module exploit/windows/smb/ms17_010_psexec...

www.r00tpgp.com

Oscp | Oscp Certification | Pentesting | Pentest | Offensive Security

3 claps



WRITTEN BY

Jie Liau

Follow

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Write the first response

More From Medium

Related reads

Windows-Based Exploitation —VulnServer TRUN Command Buffer Overflow

Andreas Poyiatzis in InfoSec Write-ups
May 30, 2019 · 6 min read ★

 321

Related reads

VulnHub — Kioptrix: Level 3

Mike Bond
Jun 1, 2018 · 14 min read

 395

Related reads

Bounty Write-up (HTB)

George O in CTF Writeups
Oct 27 2018 · 6 min read

 1.1K

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD

Oct 27, 2018 · 6 min read

Discover Medium

Welcome to a place where words matter. On Medium, smart voices and original ideas take center stage - with no ads in sight. Watch

Make Medium yours

Follow all the topics you care about, and we'll deliver the best stories for you to your homepage and inbox. Explore

Become a member

Get unlimited access to the best stories on Medium — and support writers while you're at it. Just $5/month. Upgrade

Medium

About Help Legal

Create PDF in your applications with the Pdfcrowd HTML to PDF API PDFCROWD